

# Gestión de riesgos

Un **riesgo** es el potencial de perder algo, generalmente un activo con valor para la persona u organización, como resultado de una acción. Se trata de la interacción de amenazas, vulnerabilidades y su probabilidad de actuación.

# Riesgos en activos

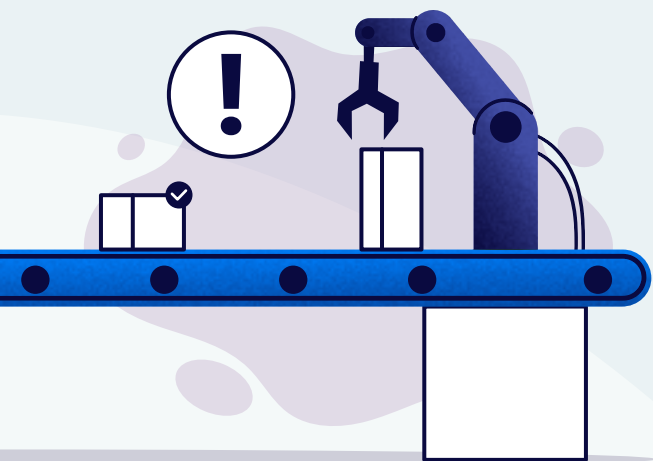
## informáticos tangibles

Para ejemplificar la identificación de los riesgos y amenazas en un activo, comenzaremos con el caso de un activo tangible: una **maquinaria que permite la operación del negocio**.

⚙️ Podemos reconocer fácilmente una **amenaza** en un terremoto, un incendio, una inundación, vandalismo o alguna institución reguladora; incluso, se puede calcular con cierta certeza la probabilidad de que la amenaza “actúe” basándose en datos históricos.

⚙️ La **vulnerabilidad** es la debilidad o falla que permite que la amenaza actúe. Por ejemplo, tener la maquinaria en un lugar que se puede inundar o incendiar, no mantener los registros legales para estar en cumplimiento, etc.

⚙️ Y, finalmente, los **riesgos** suceden cuando la amenaza actúa, por ejemplo, la pérdida de la máquina por desastre o robo, decomiso por problemas legales por incumplimiento regulatorio, etc.



Lo que sigue es determinar cuál sería el **impacto sobre la organización** si este riesgo se cumple:

- ¿Se detiene la producción y pierdo ventas?
- ¿Me hago acreedor a multas o penalizaciones?
- ¿Mi reputación puede ser afectada?

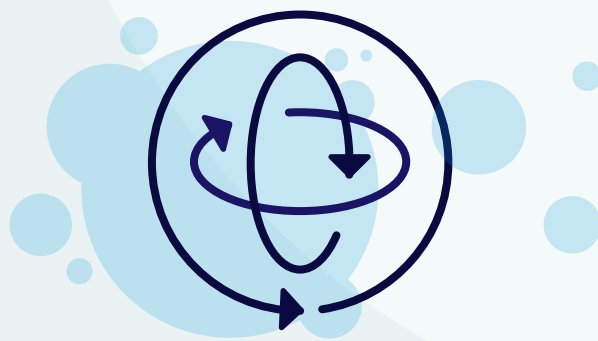
Idealmente, el impacto se mide en términos **cuantitativos** (monetarios), para poder comparar y priorizar los distintos riesgos en términos iguales. Sin embargo, un enfoque **cualitativo** también puede ser adecuado si se tienen los mecanismos para priorizar y comparar los impactos.

Una vez sabiendo el impacto de la realización del riesgo, hay que **establecer e implementar acciones para controlarlo** considerando la tolerancia de la organización al riesgo. Hay varios enfoques para responder a los riesgos; como ejemplo, el Instituto Nacional de Estándares y Tecnología de los Estados Unidos de Norteamérica (NIST), menciona (NIST, 2011):

- Aceptar el riesgo.
- Evitar el riesgo.
- Mitigar el riesgo.
- Compartir el riesgo.
- Transferir el riesgo.
- Una combinación de los anteriores.

Por ejemplo, en el caso anterior de la máquina, se puede **mitigar** el riesgo de pérdida por incendio al tener alarmas y sistemas contra incendios en el lugar donde se encuentra la máquina. Se puede **evitar** el riesgo de decomiso al tener en regla toda la papelería de cumplimiento. Si el lugar en el que se encuentra la máquina no es sísmico, podemos simplemente **aceptar** el riesgo de pérdida de la máquina por terremoto y no establecer ninguna acción.

Cada una de estas acciones se conoce como **control**, y hay que establecer mecanismos que permitan darle seguimiento continuo, es decir, saber con certeza **si el control está bien implementado, está en funcionamiento**, etc. De nada sirve un sistema contra incendios que no funciona, lo mismo para cada amenaza, vulnerabilidad y riesgo.



# Riesgos en activos

## informáticos intangibles

Ahora bien, en el caso de los activos informáticos intangibles, una vez que los hemos identificado, debemos establecer los controles para el tratamiento del riesgo, pensando en la **tríada de la ciberseguridad**, la cual consta de tres parámetros: *Confidentiality-Integrity-Availability*, a partir de los cuales recibe también el nombre de CIA.

- **Confidentiality o Confidencialidad.** La **confidencialidad** es asegurar que la información esté disponible solamente para las partes interesadas y autorizadas.
- **Integrity o Integridad.** La **integridad** indica que los datos deben mantener su consistencia y confiabilidad durante todo su ciclo de vida, además de evitar modificaciones no autorizadas, voluntarias o involuntarias.
- **Availability o Disponibilidad.** La **disponibilidad** se refiere a que la información debe estar disponible para las partes autorizadas cuando se requiera.



Considerando esto, **la aplicación de ciberseguridad requiere conocer qué ciberriesgos existen**, sobre qué **activos** aplican y cómo se deben **gestionar** para asegurar la confidencialidad, la integridad y la disponibilidad de la información.

- ¿Qué amenazas, vulnerabilidades y riesgos tiene este activo?
  - En confidencialidad.
  - En integridad.
  - En disponibilidad.
- ¿Qué prioridad tiene el activo a nivel organizacional?
- ¿Qué controles se pueden establecer?

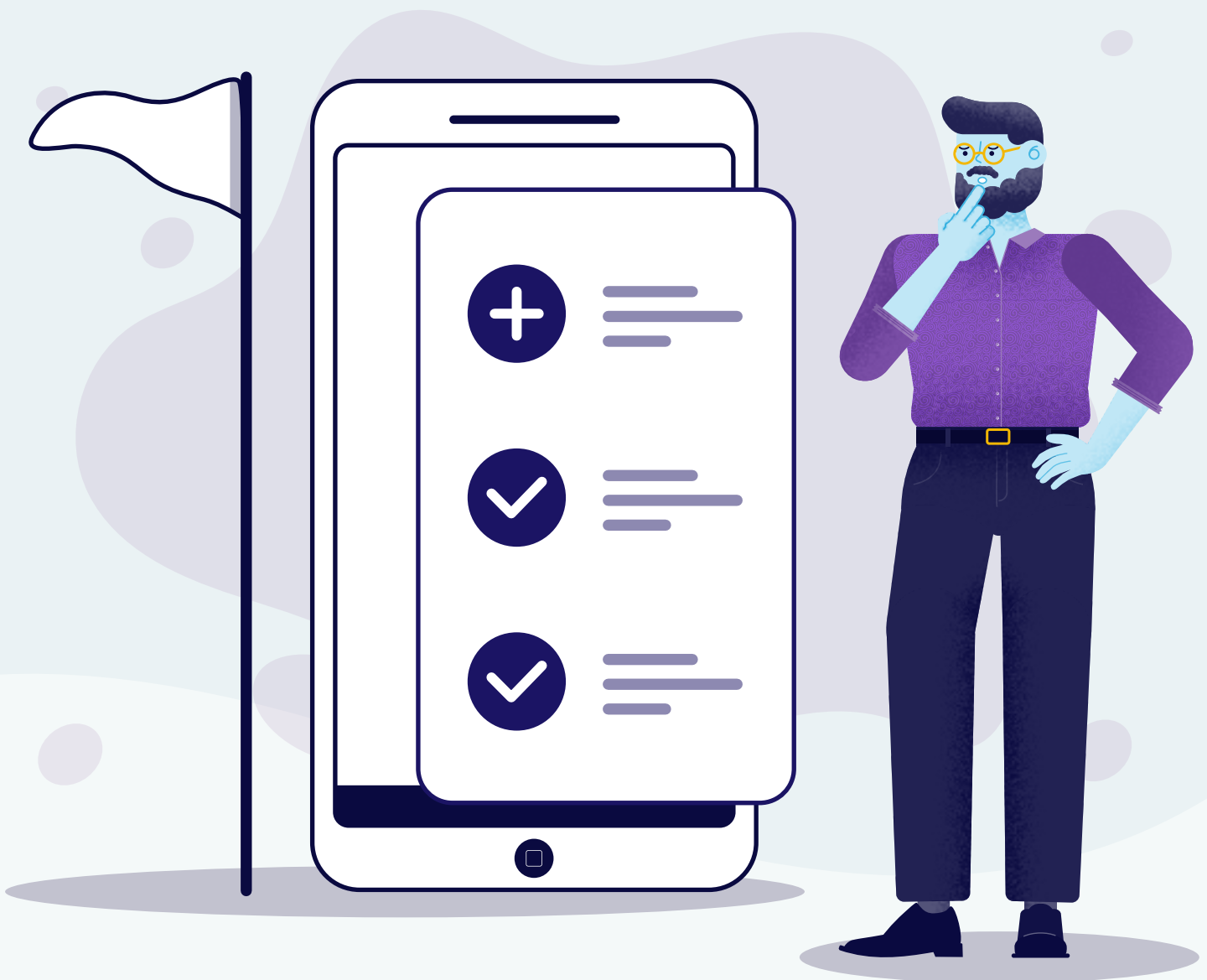
Para riesgos de **confidencialidad** se pueden establecer controles en la forma de políticas, procedimientos y herramientas tecnológicas, tales como contraseñas, autenticación de doble factor, verificación biométrica y herramientas de criptografía, además de mecanismos de filtrado y detección de intrusos en redes.

Para riesgos de **integridad**, se pueden tener mecanismos de permisos para evitar modificaciones no autorizadas, respaldos para recuperar información dañada o modificada.

Para riesgos de **disponibilidad**, se pueden establecer controles para tener mantenimiento estricto de servidores, disponibilidad de enlaces y sistemas de redundancia y respuesta a fallas.

Por otro lado, aunque normalmente pensamos en *hackers* o agentes maliciosos al realizar nuestro análisis, **muchos riesgos relacionados con la integridad y la disponibilidad son causados por desastres naturales o por descuido humano**, por ejemplo: un huracán o un terremoto pueden afectar la integridad o la disponibilidad del activo en cuestión, un usuario distraído puede borrar información importante, una mala planificación en mantenimiento y vida útil de los equipos computacionales puede afectar la disponibilidad.

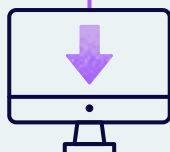
Después de identificar los activos y sus riesgos y establecer controles, hay que analizar el **costo de implementación**. El costo de gestionar un riesgo necesita ser comparado con los beneficios obtenidos o esperados, por lo que el **nivel de tolerancia** al riesgo, la **prioridad** de cada riesgo y la **respuesta** a cada tipo de riesgo considerando su impacto y probabilidad **deben ser parte de la estrategia general**, la **planificación organizacional** y la **gestión de cambios**.



## Reflexiones

Piensa en tu organización y reflexiona:

¿cuáles son los posibles riesgos, tanto para activos tangibles como intangibles?



Descarga la versión impresa en el apartado de **Archivos adjuntos** de la plataforma.